

CEHv13 AI Module 5- Vulnerability Analysis

NOTES BY VIVEK GOSWAMI

Overview

Vulnerability Analysis is a systematic process of identifying, quantifying, and prioritising security vulnerabilities in computer systems, networks, and applications. It involves a comprehensive examination, discovery, and assessment of security weaknesses that could be exploited by attackers.

What is Vulnerability Assessment?

Vulnerability Assessment is a process of examination, discovery, and identification of a system and applications security measures and weakness. It helps to recognize the vulnerabilities that could be exploited, need of additional security layers, and information that can be revealed using scanners.

Vulnerability Assessment Life-Cycle

1. Discover - Discover vulnerabilities in systems and applications
2. Prioritise - Prioritise vulnerabilities based on target, impact, loss value, business impact, etc.
3. Report - Prepare comprehensive reports on vulnerabilities
4. Remediate - Take appropriate preventive actions
5. Verify - Verify that vulnerabilities have been resolved
6. Monitor - Monitor network traffic and system behaviors for further intrusions

Overview of vulnerabilities in vulnerability scoring systems and databases:

Vulnerability databases collect and maintain information about various vulnerabilities present in information systems. They serve as centralised repositories for vulnerability details.

- **Common Weakness Enumeration (CWE)**
A community-developed list of software weakness types providing a unified language for describing software security flaws.
- **Common Vulnerabilities and Exposures (CVE)**
A dictionary of publicly disclosed cybersecurity vulnerabilities and exposures providing unique identifiers (CVE IDs) for tracking.

- **National Vulnerability Database (NVD)**
The U.S. government repository of CVE vulnerability information, enhanced with analysis, impact metrics, and severity scores.
- **Common Vulnerability Scoring System (CVSS)**
An open framework for rating the severity of vulnerabilities on a scale from 0 to 10 using metrics such as attack vector, complexity, and impact. It helps organisations prioritise vulnerability management.

CWE common weakness enumeration

Common Weakness Enumeration (CWE) is a category system for software vulnerabilities and weaknesses. It has numerous categories of weaknesses, which means that CWE can be effectively employed by the community as a baseline for identifying, mitigating, and preventing weaknesses.

Types of Vulnerability

- **Network-Based Assessment**
Detects open ports, services, and network vulnerabilities.
- **Host-Based Assessment**
Scans operating systems, installed applications, and configurations.
- **Wireless Network Assessment**
Detects insecure Wi-Fi configurations and encryption weaknesses.
- **Application-Based Assessment**
Identifies flaws in web or mobile applications.
- **Database Assessment**
Checks database security misconfigurations and vulnerabilities.

Methodology for vulnerability assessments:

- **Information Gathering**
Identify target systems and their configurations.
- **Scanning**
Use automated tools to detect vulnerabilities.
- **Analysis**
Validate results and remove false positives.
- **Prioritization**
Rank vulnerabilities based on severity (e.g., CVSS score).
- **Reporting**
Provide detailed remediation recommendations.

Common Tools for Vulnerability Analysis

- Nessus – Comprehensive vulnerability scanner.
- Nikto – Web server vulnerability scanner.
- MBSA – Microsoft Baseline Security Analyser.
- Global Network Inventory – Network asset discovery.
- Acunetix – Web vulnerability scanner.
- OpenVAS – Open-source vulnerability scanner.
- SmartScanner – General vulnerability scanning tool.
- Nmap – Service version detection and vulnerability mapping.

Vulnerability Scanner and tools

Network Vulnerability Scanner

Nmap with NSE scripts

Basic Vulnerability Scanning

General vulnerability scan

nmap --script vuln target-ip

Safe vulnerability scripts only

nmap --script safe target-ip

Specific vulnerability categories

nmap --script auth target-ip

nmap --script brute target-ip

nmap --script discovery target-ip

nmap --script dos target-ip

nmap --script exploit target-ip

Authentication bypass

Brute force attacks

Discovery scripts

Denial of service

Exploitation scripts

```

nmap --script external target-ip      # External scripts
nmap --script fuzzer target-ip        # Fuzzing scripts
nmap --script intrusive target-ip     # Intrusive tests
nmap --script malware target-ip       # Malware detection
nmap --script version target-ip       # Version detection

```

Protocol-Specific Vulnerability Testing

SMB vulnerabilities

```

nmap --script smb-vuln-* target-ip
nmap --script smb-vuln-ms17-010 target-ip      # EternalBlue
nmap --script smb-vuln-ms08-067 target-ip      # MS08-067
nmap --script smb-vuln-conficker target-ip     # Conficker

```

SSL/TLS vulnerabilities

```

nmap --script ssl-* target-ip
nmap --script ssl-heartbleed target-ip         # Heartbleed
nmap --script ssl-poodle target-ip            # POODLE
nmap --script ssl-ccs-injection target-ip     # CCS Injection

```

Web application vulnerabilities

```

nmap --script http-vuln-* target-ip
nmap --script http-shellshock target-ip        # Shellshock
nmap --script http-slowloris-check target-ip   # Slowloris DoS

```

Database vulnerabilities

```

nmap --script mysql-vuln-cve2012-2122 target-ip # MySQL auth bypass
nmap --script ms-sql-info target-ip            # MS SQL info

```

Nessus Professional

Nessus command line interface (if available)

```

nessuscli scan new --name "Vulnerability Scan" --targets "192.168.1.0/24"
--template "basic"
nessuscli scan launch "scan-id"
nessuscli scan export "scan-id" --format nessus --output report.nessus

```

Nessus Scan Types

- Basic Network Scan: General vulnerability assessment for any host using all Nessus plugins.
- Advanced Scan: Highly configurable, comprehensive vulnerability testing with additional options.
- Web Application Tests: Focused scanning of web applications for vulnerabilities.
- Malware Scan: Detects malware and backdoors on Windows and Unix systems.
- Mobile Device Scan: Assesses vulnerabilities specific to mobile devices.
- SCADA Audit: Assessment of industrial control systems for security weaknesses.

OpenVASS

OpenVAS setup and scanning

```
sudo gvm-setup          # Initial setup
sudo gvm-start          # Start services
sudo gvm-create-user admin      # Create admin user
```

Command line scanning with gvm-cli

```
gvm-cli socket --xml "<get_configs/>"          # List scan configs
gvm-cli socket --xml
"<create_target><name>Target</name><hosts>192.168.1.100</hosts></create_target>"
gvm-cli socket --xml "<create_task><name>Scan</name><config_id='config-id'><target_id='target-id'></create_task>"
gvm-cli socket --xml "<start_task task_id='task-id'>"
```

Nikto Web Server Scanner

Basic web server scanning

```
nikto -h http://target-ip          # Basic scan
nikto -h https://target-ip -ssl     # SSL scan
nikto -h http://target-ip -port 80,443,8080,8443  # Multiple ports
```

Advanced Nikto options

```
nikto -h http://target-ip -Tuning 123456789a      # All test types
nikto -h http://target-ip -evasion 12345678       # Evasion techniques
nikto -h http://target-ip -Format htm -output report.html # HTML output
```

Specific testing categories

nikto -h http://target-ip -Tuning 1	# Interesting files
nikto -h http://target-ip -Tuning 2	# Misconfiguration
nikto -h http://target-ip -Tuning 3	# Information disclosure
nikto -h http://target-ip -Tuning 4	# Injection
nikto -h http://target-ip -Tuning 5	# Remote file retrieval
nikto -h http://target-ip -Tuning 6	# Denial of service
nikto -h http://target-ip -Tuning 7	# Remote file retrieval
nikto -h http://target-ip -Tuning 8	# Command execution
nikto -h http://target-ip -Tuning 9	# SQL injection
nikto -h http://target-ip -Tuning a	# Authentication bypass

WPS- WordPress Security Scanner

WordPress vulnerability assessment

wpscan --url http://target-wordpress/	# Basic scan
wpscan --url http://target-wordpress/ --enumerate u	# Enumerate users
wpscan --url http://target-wordpress/ --enumerate p	# Enumerate plugins
wpscan --url http://target-wordpress/ --enumerate t	# Enumerate themes
wpscan --url http://target-wordpress/ --enumerate vp,vt,u	# Vulnerable plugins/themes/users

WordPress brute force attacks

```
wpscan --url http://target-wordpress/ --usernames admin,administrator
--passwords /usr/share/wordlists/rockyou.txt
wpscan --url http://target-wordpress/ --users-list users.txt --passwords
passwords.txt
```

Enhanced scanning with API token

```
wpscan --url http://target-wordpress/ --api-token YOUR_API_TOKEN
```

Owasp ZAP (Zed Attack Proxy)

ZAP command line interface

zap.sh -cmd -quickurl http://target-ip	# Quick scan
zap.sh -cmd -quickprogress http://target-ip	# Quick scan with progress

ZAP baseline scan

zap-baseline.py -t http://target-ip	# Baseline scan
zap-baseline.py -t http://target-ip -r report.html	# HTML report

ZAP full scan

zap-full-scan.py -t http://target-ip	# Full active scan
--------------------------------------	--------------------

Database vulnerability scanner

SQLmap- SQL Injection vulnerability scanner

Basic SQL injection testing

```
sqlmap -u "http://target/page.php?id=1"          # Basic test
sqlmap -u "http://target/page.php?id=1" --dbs      # List databases
sqlmap -u "http://target/page.php?id=1" -D database --tables # List tables
sqlmap -u "http://target/page.php?id=1" -D database -T table --columns # List columns
```

Advanced SQLMap techniques

```
sqlmap -u "http://target/page.php?id=1" --batch    # Non-interactive mode
sqlmap -u "http://target/page.php?id=1" --level=5 --risk=3 # Aggressive testing
sqlmap -r request.txt                             # Test from saved request
sqlmap -u "http://target/page.php?id=1" --os-shell # Get OS shell
```

NoSqlMap- NoSqlMap Injection Vulnerability Scanner

NoSQL injection testing

```
python nosqlmap.py -t http://target/login -p username,password
python nosqlmap.py -t http://target/api -p json --json
```

Protocol Specific Testing

1. SMB/Netbios Testing

SMB enumeration and vulnerability testing

```
enum4linux target-ip          # Comprehensive SMB enumeration
smbclient -L //target-ip/ -N   # List shares anonymously
smbclient //target-ip/share -N # Access share anonymously
```

SMB version detection

```
smbclient -L //target-ip/ -N | grep "Domain=" # Get domain info
rpcclient -U "" -N target-ip                  # RPC null session
```

Test for SMB vulnerabilities

```
nmap --script smb-vuln-ms17-010 target-ip      # EternalBlue test
nmap --script smb-security-mode target-ip      # Security mode check
```

2. Ftp Testing

FTP vulnerability testing

```
ftp target-ip # Manual FTP connection
nmap --script ftp-anon target-ip # Anonymous FTP check
nmap --script ftp-bounce target-ip # FTP bounce check
nmap --script ftp-vsftpd-backdoor target-ip # VSFTPD backdoor check
```

FTP brute force

```
hydra -l admin -P passwords.txt target-ip ftp
medusa -u admin -P passwords.txt -h target-ip -M ftp
```

3. SSH Testing

SSH vulnerability assessment

```
ssh-audit target-ip # SSH configuration audit
nmap --script ssh-hostkey target-ip # SSH host key info
nmap --script ssh-auth-methods target-ip # Supported auth methods
```

SSH brute force

```
hydra -l root -P passwords.txt target-ip ssh
medusa -u root -P passwords.txt -h target-ip -M ssh
```

Web Application Manual Testing

Directory enumeration

```
gobuster dir -u http://target-ip -w /usr/share/wordlists/dirb/common.txt
dirbuster -u http://target-ip -l /usr/share/wordlists/dirb/big.txt
```

Technology detection

```
whatweb http://target-ip # Web technology detection
wafw00f http://target-ip # WAF detection
```

SSL/TLS testing

```
sslscaan target-ip # SSL configuration scan
testssl.sh target-ip # Comprehensive SSL test
```

Defensive Countermeasures

- Regular patching and updates.
- Disable unused ports and services.
- Implement network segmentation.
- Deploy intrusion detection/prevention systems (IDS/IPS).
- Conduct regular vulnerability scans.

Additional best practices in 2025 include:

- Enforce multi-factor authentication (MFA) for access control.
- Implement a zero-trust network architecture, verifying every access request.
- Use Security Information and Event Management (SIEM) and continuous monitoring for real-time threat detection.
- Perform regular penetration testing and security awareness training.
- Secure remote access via VPNs and Zero Trust Network Access (ZTNA).
- Employ microsegmentation to limit lateral movement inside networks.
- Harden configurations, disable or remove obsolete protocols and services.
- Maintain endpoint detection and response (EDR) capabilities.
- Use strong encryption for data in transit and at rest.

Perform Vulnerability Analysis using A.I

Perform Vulnerability Analysis using ShellGPT

Launching Nikto Scan

```
sgpt --chat nikto --shell "Launch nikto to execute a scan against the URL www.certifiedhacker.com to identify potential vulnerabilities."
```

Nmap Vulnerability Scan

```
sgpt --chat vuln --shell "Perform vulnerability scan on target url http://www.moviescope.com with Nmap"
```

Using the Skipfish tool

```
sgpt --chat vuln --shell "Perform a vulnerability scan on target url http://testphp.vulnweb.com with skipfish"
```

The skipfish begins scanning the target url. After the successful completion of the scan, report is saved at the **/tmp/skipfish_scan_output/** location, named as **index.html**.

